

## Section 08



# Industrial Security (Bachelor)

## Section 08 – Defense in Depth

### **Defense in Depth**

*Lecture Notes*

Department of Computer Science

- 1 Layered Controls
- 2 Access and Remote Support
- 3 Patching, Backups, Monitoring

## By the end of this section you will be able to

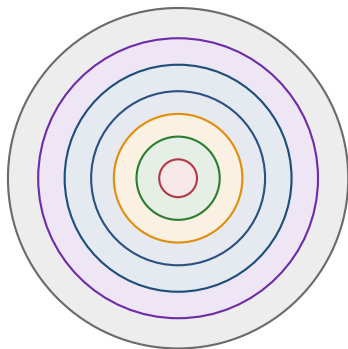
- Apply defense-in-depth across people, process, and technology.
- Design layered controls for an ICS environment.
- Specify secure remote access patterns for vendors.
- Position passive ICS IDS and explain alert triage.

# 1

---

## Layered Controls

Section 08 – Defense in Depth



- ■ Policies & procedures
- ■ Physical security
- ■ Network segmentation
- ■ Host hardening
- ■ Application & RBAC
- ■ Data & backups
- ■ Monitoring & IR

## Layered

A single failed layer should not equal a successful attack.

Source: INL, *Recommended Practice: Improving ICS Cybersecurity with Defense-in-Depth Strategies*, 2016 | NIST SP 800-82 Rev. 3, 2023.

Remove or disable USB, optical, unused services

CIS Benchmarks adapted for OT availability constraints

Application whitelisting (AppLocker, McAfee Solidcore)

Local firewalls with explicit allowlists

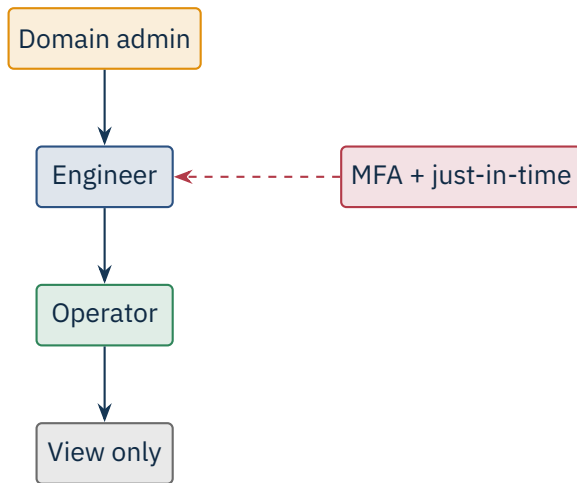
Vendor-approved AV signatures only

# 2

---

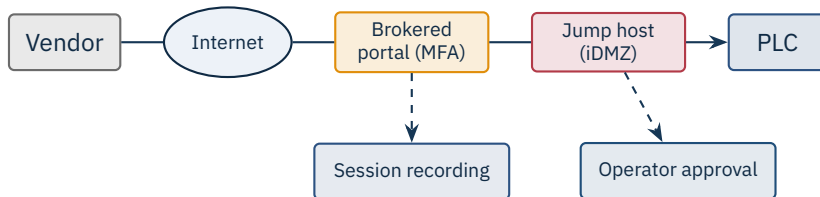
## **Access and Remote Support**

Section 08 – Defense in Depth



Per-person accounts, no shared logins. Keep a local fallback in case AD goes down.



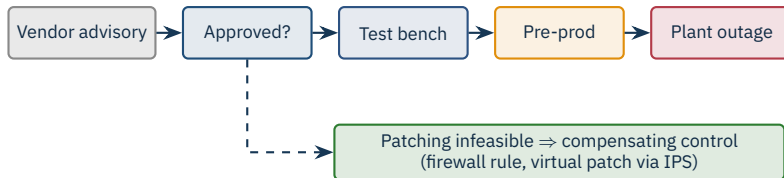


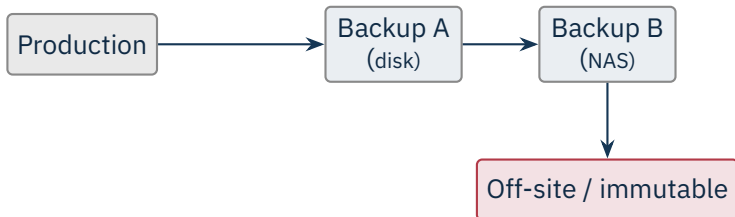
# 3

---

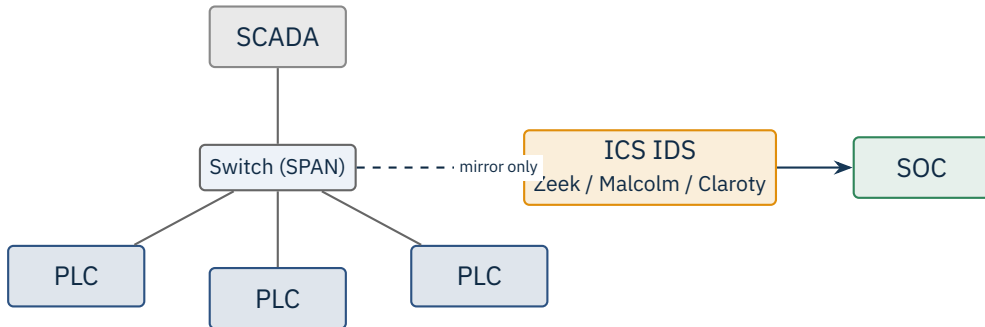
## Patching, Backups, Monitoring

Section 08 – Defense in Depth





Back up: PLC programs (with checksums), HMI projects, engineering workstations, historian DB, switch configs. Restore-test regularly.



Source: Tools: Zeek (Paxson, 1999); Malcolm (Idaho National Lab); commercial: Claroty CTD, Nozomi Guardian, Dragos Platform.

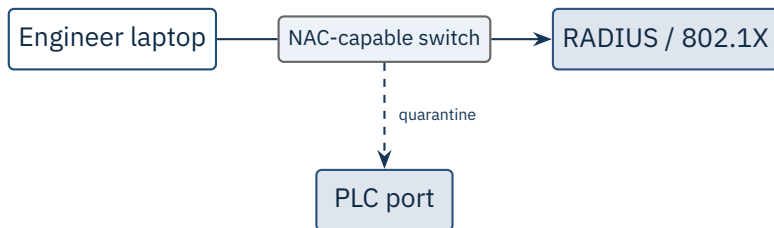
New device joining (MAC unseen)

Unexpected Modbus function code (e.g. write coil from HMI subnet)

Engineering download outside scheduled change window

Outbound connection from PLC to Internet

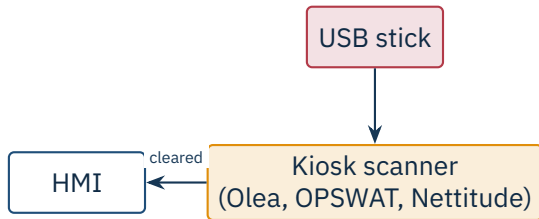
PLC mode change (RUN → STOP)



## Sealing the wall jack

802.1X (with MAC bypass for legacy devices) prevents random laptops from joining the plant LAN. Static PLC ports get MAC pinning.

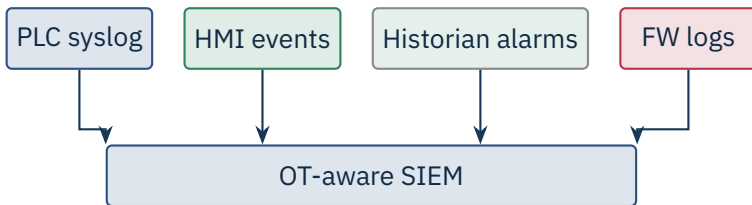
*Source: IEEE 802.1X-2020 | NIST SP 800-92 (logging) | vendors: Cisco ISE, Aruba ClearPass, Forescout eyeSight.*



### One door

Every USB must pass through one of N approved scanning kiosks before it touches an HMI. Block all other USB at the OS level.





## Send everything, correlate centrally

Most ICS devices have weak logging – compensate with network IDS and host-based agents on the windows-class assets.

- Honey-PLCs / honey-HMIs lure scans and exploit attempts.
- Decoy credentials (canary tokens) trip alerts when used.
- Fake assets in DNS / Active Directory.
- False engineering-WS hostnames as tripwires.

### Low cost, high signal

A honey-PLC sees *zero* legitimate traffic by design – any hit is a near-certain incident.

### ★ Key Takeaway: What to remember from this section

- Defense in depth layers people, process, and technology.
- Hardening and application whitelisting fit well on static HMIs.
- Brokered, recorded, approved remote access beats open VPNs to the plant.
- Passive OT IDS provides visibility without injecting traffic into production.

- Idaho National Lab. *Recommended Practice: Improving Industrial Control System Cybersecurity with Defense-in-Depth Strategies*, 2016.
- NIST SP 800-82 Rev. 3. *Guide to OT Security*, Sep 2023.
- CIS. *CIS Critical Security Controls v8*, 2021.
- CIS Benchmarks (Windows, Linux). Center for Internet Security.
- NIST SP 800-167. *Guide to Application Whitelisting*, 2015.
- NIST SP 800-92. *Guide to Computer Security Log Management*, 2006.
- IEEE 802.1X-2020. *Port-based network access control*.
- Paxson, V. “Bro: A System for Detecting Network Intruders in Real-Time.” *Computer Networks*, 1999 (Zeek origin).
- Open Information Security Foundation. *Suricata IDS*, <https://suricata.io>.
- Idaho National Lab. *Malcolm network monitor*, <https://github.com/idaholab/Malcolm>.
- NIST SP 800-46. *Guide to Enterprise Telework, Remote Access, and BYOD Security*, 2016.
- CISA. *Recommended Cybersecurity Practices for Industrial Control Systems*, 2020.

# End of Section 08



Defense in Depth

Questions and discussion